



Tyk Onboardin g

Sr. Customer Solutions Architect



Module 2

Single Sign-On

Single Sign-On

Authenticate once, access multiple apps without re-entering credentials.

- **Benefits:**

- Centralized identity management
- Consistent access policies
- Reduced password fatigue
- Faster onboarding/offboarding

- **Protocols:**

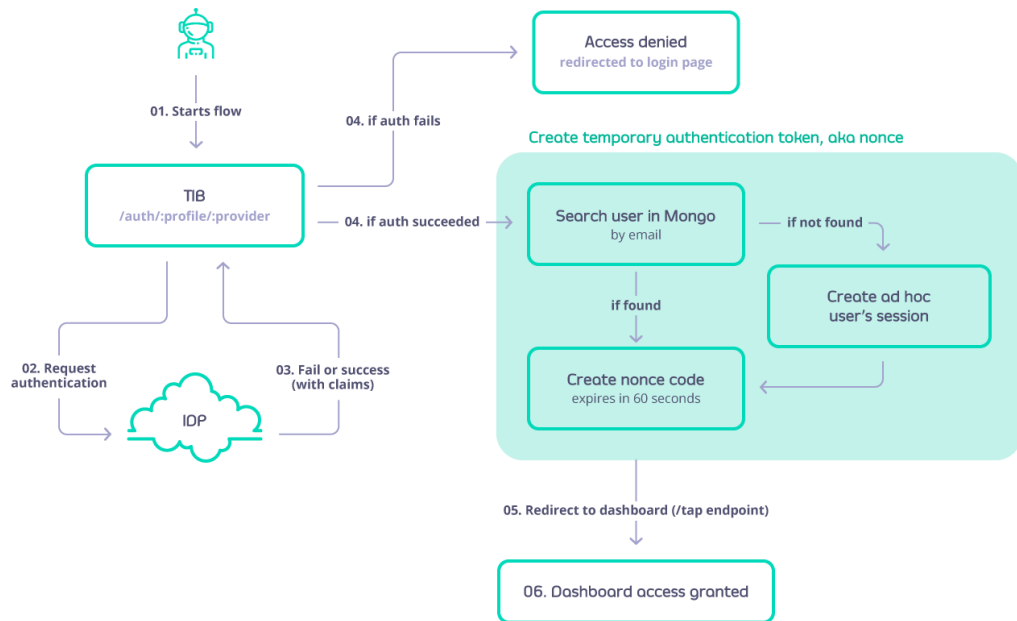
- OpenID Connect (OIDC)
- OAuth 2.0
- SAML 2.0
- LDAP/Active Directory

Tyk Identity Broker

- TIB bridges your Identity Management Systems with Tyk Dashboard, Portal & Gateway
- Middleware between Identity Providers (IdPs) and Tyk
- Key Use Cases:
 - SSO for Dashboard or Portal
 - Social logins (Google, GitHub, etc.)
 - LDAP/AD for internal teams
 - Token generation for mobile/web apps
- Built-in since Tyk v3.0
- Two Modes:
 - Internal TIB: embedded in Dashboard
 - External TIB: standalone service

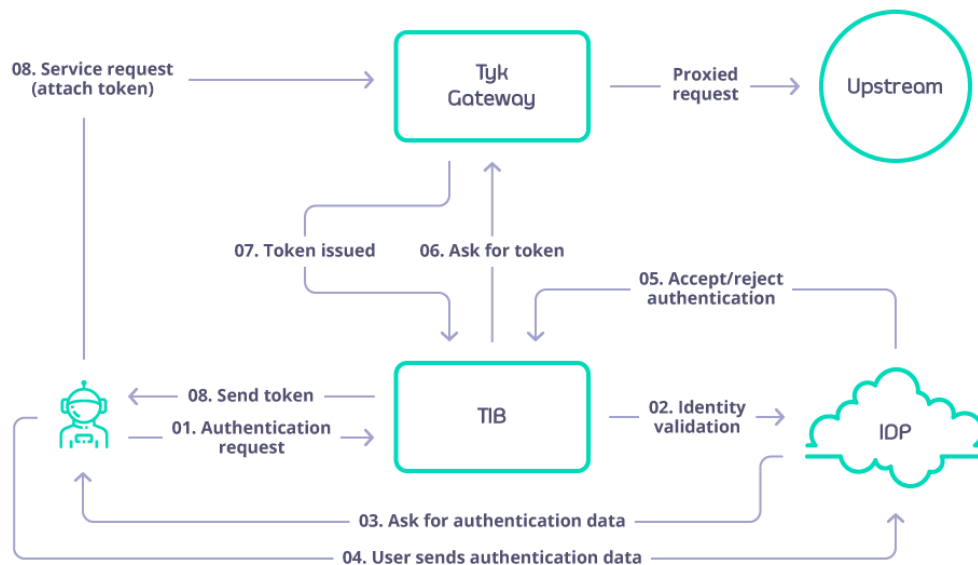
SSO Flow

1. User initiates login via SSO endpoint.
2. TIB redirects to IDP for authentication.
3. Keycloak validates user and returns ID token.
4. TIB verifies token and searches in database for user
 - If found, nonce code created
 - If not found, ad hoc user session is created
5. Redirects to Dashboard



Authentication Flow

1. User initiates authentication via TIB
2. TIB validates identity via IDP
3. IDP requests for authentication data from the client
4. TIB receives accepted or rejected response from IDP
5. TIB requests for token from Tyk Gateway
6. Returns token to client
7. Client can now make a request to the Gateway



TIB Architecture

Request Flow:

1. User attempts login
2. TIB matches request to a Profile
3. Profile invokes:
 - Identity Provider → validates identity
 - Identity Handler → maps to Tyk (Dashboard, Portal, OAuth)

Identity Providers

- Social: Google, GitHub, Twitter, Bitbucket, etc.
- LDAP: Validate username/password against LDAP server
- Proxy: Forward to external service, validate by status/response
- SAML: Authenticate against enterprise SAML IdP

Identity Handlers

- `GenerateOrLoginUserProfile` → **Dashboard SSO**
- `GenerateOrLoginDeveloperProfile` → **Portal SSO**
- `GenerateOAuthTokenForClient` → **Issue Tyk OAuth token**

Profiles

- Profiles define how a Provider + Handler + Action fit together
- Stored in MongoDB or file depending on setup
- Dashboard UI simplifies management
- Example: Azure AD (OIDC) → TIB → Dashboard SSO

Anatomy of a Profile

- Core Fields: ID, OrgID, ActionType, Type, ReturnURL
- Optional Fields: Group mappings, email claims, user ID claims
- Security: Restrict SSO to registered users
- Example JSON profile snippet shown in workshop

Provider-Specific Fields

- LDAP: server, port, DN, filters, attributes
- Proxy: target host, OKCode/Response/Regex, token field
- Social: callback URLs, provider keys/secrets, scopes
- SAML: metadata URL, certs, entity ID, redirect URLs

```
{
  "ActionType": "GenerateOAuthTokenForClient",
  "ID": "keycloak-profile",
  "OrgID": "ORG_ID",
  "IdentityHandlerConfig": {
    "DashboardCredential": "DASHBOARD_ADMIN_API_KEY",
    "PolicyID": "POLICY_ID"
  },
  "IdentityProvider": {
    "Name": "OpenIDConnect",
    "OpenIDConnectConfig": {
      "ClientID": "tyk-tib",
      "ClientSecret": "SECRET",
      "CallbackBaseURL": "http://<TIB_HOST>:3010/auth/keycloak-profile/openid-connect/callback",
      "IssuerURL": "http://<KEYCLOAK_HOST>/realms/TykSSO"
    }
  }
}
```

- **ID** – Profile name
- **OrgID** – Tyk Organization ID
- **ActionType** – Action to perform (e.g., GenerateOAuthTokenForClient)
- **IdentityHandlerConfig** – Policy, API, Dashboard mapping
- **IdentityProvider** – IdP type & configuration

Hands-On Workshop

Hands-On Workshop

```
# Add Bitnami Helm repository  
  
helm repo add bitnami https://charts.bitnami.com/bitnami  
  
helm repo update
```

```
# Install Keycloak with Helm  
  
helm install keycloak bitnami/keycloak \  
  --namespace keycloak \  
  --create-namespace \  
  --set auth.adminUser=admin \  
  --set auth.adminPassword=admin \  
  --set service.type=NodePort \  
  --set service.nodePorts.http=30082 \  
  --set service.nodePorts.https=30083
```

Hands-On Workshop

1. In your desired Realm, create a client of OpenID Connect type, and set your desired Client ID.
2. Enable client authentication, then save the client.
3. Retrieve the Secret (from the credentials tab) of the Client you just created.
4. Retrieve the well known endpoint of the realm.
 - a. Accessible from “Realm Settings” > “General” Tab > OpenID Endpoint Configuration.

Hands-On Workshop

1. Log in to your Dashboard and select Identity Management, located under System Management.
2. Create a profile, give it a name and select “Login to Tyk Dashboard”.
3. Set the provider type as “OpenID Connect”.
4. Fill in the Client ID, Client Secret and Discovery URL/endpoint from Keycloak.
5. Copy the callback URL from Tyk and then you can click “Create Profile” to save the profile.
6. Go to Keycloak, and paste the callback URL you just copied to “Valid redirect URIs” in the Keycloak Client, and then save the client.
 - a. This can be accessed by selecting the “Settings” tab when viewing a Keycloak client.
7. Save the profile.

Hands-On Workshop

1. From your Identity Management Profiles click the profile you created to open it.
2. Copy the Login URL and paste it into a browser tab.
3. You will now see the Keycloak login form.
4. Enter the email address and password of your Keycloak user.
5. You should now be redirected to the Tyk Dashboard and logged in.